

Project ONYX

Enterprise GRC Intelligence Platform — Case Study

ARCHITECTURE REFERENCE

SECTION 01

Challenge Framing

Regulated enterprises are operating GRC programs built on a structural flaw. Security operations teams manage threat detection and incident response through SIEM platforms. Compliance teams manage regulatory obligations through spreadsheets and periodic manual assessments. These two functions share the same underlying risk data — but rarely share tooling, workflows, or a common risk language.

The result is a persistent gap between an organization's actual security posture and its documented compliance posture. Infrastructure changes daily. Vulnerabilities are introduced continuously. But compliance evidence is gathered quarterly, assessed annually, and reported in formats that offer little operational value between review cycles.

The core problem is not a lack of security tooling — enterprises already invest heavily in point solutions. The problem is a lack of integration. Risk findings generated by infrastructure scanning rarely reach compliance posture in time to matter. Remediation workflows are reactive and ad hoc. Financial exposure from technical vulnerabilities is rarely quantified in terms that resonate at the board level.

This fragmentation has compounding consequences. Auditors receive inconsistent, manually assembled evidence packages. Engineers receive vulnerability findings without actionable remediation context. CISOs prepare board presentations that translate CVSS scores into business language without systematic tooling support. Organizations subject to multiple overlapping frameworks — NIST SP 800-53, SOC 2 Type II, ISO 27001, PCI-DSS 4.0, HIPAA — duplicate control assessment work across teams with no unified mapping layer.

In regulated sectors — financial services, healthcare, defense, and cloud infrastructure — the cost of these gaps is not just operational inefficiency. It is audit exposure, regulatory penalty risk, and breach impact that was foreseeable but not surfaced through the existing compliance architecture.

SECTION 02

Platform Design Response

Project ONYX is an enterprise GRC intelligence platform designed to close the gap between security operations and compliance functions. It is architected as an orchestration layer — not a replacement for existing security tooling, but a unifying intelligence layer that ingests telemetry from existing sources, maps findings to compliance

requirements in real time, and delivers a single operational interface for GRC analysts, security engineers, and executive leadership.

Four-Layer Architecture

Layer	Name	Function
	UI Layer	Unified operational dashboard — risk topology visualization, compliance posture heatmaps, financial
L2	Orchestration Engine	Coordinates data ingestion, module execution sequencing, AI inference calls, and output delivery —
	Analytical Processing	Risk scoring, financial exposure calculation, multi-framework compliance mapping logic, sandboxed
L4	Secure Data Vault	Encrypted log storage, audit trail persistence, framework configuration repository, remediation runbo

Data Flow Narrative

Infrastructure logs, cloud audit trails, and endpoint telemetry are collected by the parsing engine, which normalizes raw events into a common schema. The risk scoring module applies a multi-factor model — likelihood, asset criticality, and threat context — to each normalized event. High-severity findings trigger the financial exposure calculator, producing dollar-range impact estimates alongside technical severity ratings.

Scored findings are then cross-referenced against the active compliance profile by the mapping module, which maintains a unified control library spanning NIST SP 800-53, SOC 2 Type II, ISO 27001, PCI-DSS 4.0, and HIPAA. Control-level status updates propagate in real time. For prioritized findings, the local AI inference engine generates contextualized remediation runbooks — operating entirely within the customer's security boundary. All outputs surface in the unified dashboard as risk topology maps, compliance heatmaps, and prioritized remediation queues.

SECTION 03

Capability Deep-Dives

Log Ingestion & Parsing Engine

Accepts structured and semi-structured telemetry from multiple source types — syslog, Windows event logs, cloud audit trails (AWS CloudTrail, Azure Monitor), and endpoint detection feeds. A normalization layer transforms raw events into a common schema before downstream processing. The connector architecture supports extensibility for new source types without core platform modifications.

- Multi-source telemetry ingestion with schema normalization
- Deduplication and classification by severity, asset, and event type
- Connector-based extensibility for new log source types

Risk Scoring & Financial Exposure Engine

Applies a multi-factor risk scoring model to normalized events. Factors include event likelihood, asset criticality classification, and available threat context. High-severity findings trigger the financial exposure calculator, which estimates potential impact ranges based on asset classification, applicable regulatory penalty frameworks, and breach cost reference data. This module is the primary differentiator for executive communication — translating CVSS scores into dollar exposure ranges that support board-level risk investment decisions.

- Multi-factor risk scoring: likelihood × asset criticality × threat context
- Financial impact estimation expressed as dollar exposure ranges
- Risk-based prioritization for remediation queue ordering

Multi-Framework Compliance Mapping

Maintains a curated control library spanning NIST SP 800-53, SOC 2 Type II, ISO 27001, PCI-DSS 4.0, HIPAA Security Rule, and CIS Controls. Risk findings are cross-referenced against the active compliance profile, producing control-level pass/fail/partial status updates. A finding mapped once propagates to all relevant frameworks simultaneously — eliminating the duplicated manual cross-walk work that burdens compliance teams in multi-framework environments.

- Unified control library across six major compliance frameworks
- Real-time control status updates driven by infrastructure events
- Eliminates manual framework cross-walk for overlapping control sets

Remediation & Runbook Generation

For each prioritized finding, the module retrieves or generates a remediation runbook — step-by-step technical guidance scoped to the specific configuration, platform, and control family. The local AI inference layer assists with runbook generation for novel or complex findings. All AI-generated outputs are flagged as drafts pending analyst review before being committed to the runbook store or surfaced to engineering teams. Runbooks are versioned and stored in the secure data vault for audit reference.

- Pre-staged runbooks scoped to asset, platform, and control family
- AI-assisted generation for novel findings with human-in-the-loop review
- Versioned runbook store in audit-trail-linked secure vault

Risk Topology Visualization

A graph-based visualization layer renders the risk landscape as an interactive topology — showing relationships between assets, risk findings, compliance gaps, and financial exposure. CISOs and compliance leads can drill from a compliance heatmap into specific control failures, down to the originating infrastructure events. The visualization supports both operational investigation (root-cause analysis, impact tracing) and executive reporting (board-ready risk narratives) from the same underlying data layer.

- Interactive risk topology linking assets, findings, and compliance gaps
- Drill-down from compliance heatmap to originating infrastructure events
- Dual-purpose design supporting both analyst investigation and executive reporting

SECTION 04

AI Governance & Security Design

AI-assisted GRC tooling introduces a fundamental tension in regulated environments. The same intelligence capabilities that improve risk analysis and remediation quality also create new attack surfaces, data residency concerns, and explainability obligations. Organizations subject to GDPR, HIPAA, FedRAMP, or SOX cannot simply route infrastructure logs through a third-party cloud AI API and expect compliance teams, legal counsel, or auditors to accept the arrangement without significant scrutiny.

ONYX addresses this tension through a local-first inference architecture with layered governance controls. The design rationale for each control is as important as the control itself — these are not checkbox security features, they are architectural decisions made in response to specific regulatory constraints and enterprise risk requirements.

Local and Offline Inference

All AI inference runs within the customer's security boundary. The design supports air-gapped and restricted-network deployment environments. This is not merely a privacy preference — it is an architectural decision that makes ONYX viable in sectors where cloud AI tooling would require extensive legal review and vendor due diligence under data processing agreements.

Context-Grounded Processing

The inference engine operates only on structured context passed by the orchestration layer. It has no persistent memory, no direct access to raw infrastructure data, and cannot initiate external requests. This constraint bounds the AI layer's operational scope and limits the blast radius of a potential model failure or adversarial input.

Audit Logging of AI Outputs

Every AI-generated output — remediation runbook, risk summary, compliance narrative — is logged with the model version, input context hash, and timestamp. This creates a traceable evidence chain for audit purposes, enabling reviewers to reconstruct the basis for any AI-assisted recommendation.

Sandboxed Execution Controls

The inference process runs in an isolated execution environment with enforced resource limits, output size constraints, and injection protections. The AI layer cannot affect platform state beyond its designated output channel — it produces text artifacts that humans review, not actions that execute.

Data Containment Strategy

Sensitive fields — hostnames, user identities, network addresses, and asset identifiers — are masked or tokenized before being passed to the inference engine. The model receives sufficient context to generate useful remediation guidance without accessing raw PII or classified infrastructure details.

Human-in-the-Loop Validation

AI-generated remediation guidance is flagged as draft output pending analyst review before it is committed to the runbook store or surfaced to engineering teams. The platform does not auto-execute AI recommendations. This preserves human accountability in the remediation chain.

The local-first architecture makes ONYX viable for environments with strict data residency requirements — including government entities subject to FedRAMP, healthcare organizations under HIPAA, and financial institutions under SOX and GDPR — where cloud-based AI tooling would require extensive legal review and ongoing vendor risk assessment.

SECTION 05

Business Value & Design Principles

The business case for ONYX is grounded in reducing the operational cost of compliance and improving the quality of risk-based decisions — not adding another point tool to an already crowded security stack. The platform is designed to deliver measurable operational improvement in six areas:

Improved audit readiness	Continuous compliance mapping replaces periodic manual evidence gathering. Structured, timestamped evidence collection replaces manual evidence gathering.
Faster incident response	Pre-staged runbooks eliminate ad hoc research. Analysts receive actionable remediation guidance.
Executive risk visibility	Financial exposure translation bridges the CISO-to-board communication gap — risk in dollar terms.
Reduced compliance effort	Unified multi-framework mapping eliminates duplicated control cross-walk work for teams managing multiple frameworks.
Effective risk prioritization	Risk scoring plus financial exposure enables business-risk-led remediation queue ordering, not severity.
Regulatory defensibility	Documented audit trail, AI governance controls, and continuous posture provide a defensible risk management process.

Design Principles

Several architectural principles guided the ONYX design and are worth making explicit — particularly for regulated industry contexts where platform design choices carry compliance implications:

- Telemetry-driven over assertion-driven: compliance posture derived from observable infrastructure state, not self-reported survey responses.
- Financial translation as a first-class output: risk quantification in business terms is not an afterthought — it is a core module output.
- Local-first AI as a compliance decision: the choice to run inference on-premises is an architectural constraint, not merely a security preference.
- Human accountability in the AI chain: AI outputs are always advisory and always reviewed — the platform does not substitute AI judgment for human decision-making.
- Unified data layer for all personas: GRC analysts, security engineers, and executive leadership work from the same underlying risk intelligence.

Positioning Statement

Project ONYX is a portfolio-grade, architect-designed GRC intelligence platform demonstrating depth in enterprise risk platform design, AI governance in regulated environments, and unified security-compliance orchestration. It is designed for regulated industries where compliance continuity, financial risk visibility, and data residency are non-negotiable constraints — and where the gap between security operations and compliance functions carries measurable business and regulatory risk.

This document is intended for use in technical interviews, portfolio presentations, procurement submissions, and architectural reviews. All claims are design objectives grounded in realistic implementation scope. No production deployment metrics are represented.

APPENDIX

Future Roadmap

Phase	Enhancement	Rationale
Phase 1	SIEM integrations (Splunk, Sentinel, QRadar)	Enable ONYX to ingest normalized alert streams from existing enterprise
Phase 1	JIRA / ServiceNow ticketing integration	Bidirectional remediation workflow — create tickets from findings, close co
Phase 1	Expanded cloud log ingestion (GCP, AWS Security, Azure, CloudTrail)	Broader coverage for organizations using multi-cloud or hybrid archi
Phase 2	Predictive risk modeling	ML layer surfacing likely future exposure areas from historical telemetry tr
Phase 2	Automated control testing	Active validation confirming controls function as documented, beyond pas
Phase 2	Regulatory update tracking	Automated monitoring of framework revisions with impact analysis on map
Phase 3	Advanced network telemetry (NetFlow, DNS, east-west)	Internal movement detection and anomalous communication pattern identi
Phase 3	Third-party / TPRM module	Vendor risk questionnaires and third-party telemetry feeds integrated into
Phase 3	Multi-tenant deployment model	Tenant-isolated architecture enabling MSSPs and consulting firms to serv